Why 20

01 · WHY 20 POINTS NOT 12

Three regulatory shifts turned ESG and cyber into compliance, not values.

In 2019, a 12-point checklist was sufficient. By 2026, three new directives have moved ESG, cyber, and forced labour from "monitor" to "verify per supplier" — under penalty.

Phase 1 (large EU listed) reporting Y2024 data Jan 2025. Phase 2 (large non-listed) Y2025 data. Phase 3 (SMEs listed) Y2026 data. Each scope-in company must report supplier ESG data.

CSRD · IN FORCE 2024

50,000 — EU companies in scope by 2026

SOURCE: EU Directive 2022/2464 · ESMA implementing standards

Iron, steel, aluminium, cement, fertiliser, electricity, hydrogen. Importers must verify supplier emissions. Plastics + chemicals scope expansion proposal 2025-2026.

CBAM · DEFINITIVE PHASE

€85-170 — per tonne (steel) 2026 → 2028

SOURCE: EU Reg 2023/956 + Implementing Reg 2023/1773 · S&P Global Carbon Q1 2026

US CBP detained 9,800+ shipments 2022-2025 under UFLPA. 62 entities on banned list (May 2024). Burden of proof on importer. Detention costs $50k-200k per container.

UFLPA · ENFORCED

75% — of detained shipments rebuttable presumption

SOURCE: 19 USC § 1307(b) · CBP UFLPA Enforcement Statistics 2025

Sources: EU Directive 2022/2464 · 19 USC § 1307(b) · CBP statistics 2025

Regulatory Timeline

02 · REGULATORY TIMELINE

2024 → 2030. Four directives. Six phase-in milestones.

Each directive's phase-in creates new audit obligations on your suppliers. Plan ahead — by Q2 2027, your supplier audit cycle will need to cover all four regimes simultaneously.

PHASE-IN TIMELINE · 4 DIRECTIVES

2024

2025

2026

2027

2028

2029

2030

CSRD

P1 large listed

P2 large non-listed

P3 SME listed

steady state

phased reporting

CBAM

transitional rep.

definitive €85-170/t

full rate · 2034 sunset

definitive phase

CSDDD

transposition into NL

phase 1 large

phase 2 mid+civil liability

due diligence

FLR

Reg 2024/1781 · enforcement Jun 2025

forced labour

UFLPA

rebuttable presumption · weekly entity list

ongoing US

CRITICAL — Q2 2027 INFLECTION

By Q2 2027, your supplier audit cycle covers CSRD ESG data + CBAM verified emissions + CSDDD due diligence + FLR forced-labour + UFLPA verification. 5 frameworks per supplier. Build the muscle now.

Sources: EU 2022/2464 · 2023/956 · 2024/1760 · 2024/1781 · 19 USC § 1307(b)

Pentagon

03 · FIVE-DIMENSION PENTAGON

Score every supplier on five axes. Single low score = walk away.

Financial · Operational · Geopolitical · ESG · Cyber. The 20 checks distribute 4 per axis. A supplier scoring 4/5 on average but 0/5 on any single axis is a walk-away — supply chain failure modes are dimensional.

SAMPLE SUPPLIER · 5-DIMENSION SCORE · 1-5 SCALE

FINANCIAL

CYBER

OPERATIONAL

ESG

GEOPOLITICAL

FINANCIAL

OPERATIONAL

GEOPOLITICAL

ESG

CYBER

GOOD

WATCH

FLAG

GOOD

WATCH

audited Y3 + bank ref OK

single-site dependency

sanctions partial match

EcoVadis Silver

ISO 27001 expired 8mo

Methodology: composite scoring framework · ISO 31000 + COSO ERM aligned

Source Library

04 · SOURCE LIBRARY

Twenty-three named data sources. By region and access tier.

Each check has 1-3 named primary data sources. Bookmark these in your team's audit toolkit. Free sources first, paid only when criticality justifies.

FREE

FREEMIUM

PAID

9 sources

6 sources

8 sources

KRS

Creditreform

D&B Financial Stress

krs.ms.gov.pl

creditreform.de

dnb.com

PL legal entity registry

Basic free · full €

Default probability

VIES

ITC Standards Map

LSEG World-Check

ec.europa.eu/.../vies

standardsmap.org

lseg.com

EU-wide VAT verification

Cert verification

PEP · sanctions · adverse

Companies House

IATF Database

LSEG Credit Ratings

companieshouse.gov.uk

iatf.org

lseg.com/refinitiv

UK entity + directors

IATF cert holders search

Counterparty ratings

Bundesanzeiger

CDP Supply Chain

EcoVadis Full

bundesanzeiger.de

cdp.net

ecovadis.com

DE filings + audited fin.

Climate disclosure

Sustainability scorecard

OFAC SDN

ICRG Risk

Sedex SMETA

sanctionssearch.ofac.treas.gov

prsgroup.com

sedex.com

US sanctions · weekly

Country risk scoring

Ethical 4-pillar audit

EU Sanctions

NCSC Alerts

DarkOwl

webgate.ec.europa.eu/fsd

ncsc.gov.uk

darkowl.com

Consolidated EU list

UK cyber alerts

Deep · dark web monitor

Have I Been Pwned

SpyCloud

haveibeenpwned.com

spycloud.com

Breach exposure check

Stolen creds · breach

ECHA SVHC

FT/Reuters/Bloomberg

echa.europa.eu

subscriptions

REACH chemicals list

Adverse media coverage

Sources: see Block 3 — research brief; methodology references compiled Apr 2026

CISA KEV

cisa.gov/known-exploited

Active CVEs

Decision Flow

05 · WHICH AUDIT FOR WHICH SUPPLIER

5-min quick-scan · 45-min standard · Full-day deep audit.

Decision flow based on category criticality, spend, and tier. Run quick-scan on 80% of suppliers. Reserve deep audit for Tier-1 strategic + safety-critical.

1. New supplier or re-check?

RE-CHECK

NEW

→ Run quarterly cadence cycle (p.16)

2. Single-PO purchase < €25k?

YES

NO

QUICK-SCAN · 5 MIN Checks #1, 9 only · approve or escalate

3. Tier-1 strategic or safety-critical?

YES

NO

STANDARD · 45 MIN All 20 checks · 2-3 days for red-flag resolution

4. *€500k spend or IP-sensitive?*

YES

NO

DEEP AUDIT · 1-2 DAYS 3rd-party + on-site

STANDARD + sample audit

Framework: Procurea decision tree · ISO 31000 risk-tiering aligned

Financial

06 · FINANCIAL HEALTH · CHECKS 1-4

Financial. The basics non-negotiable.

Legal entity exists & matches quote

Credit score acceptable · no recent default

#01

#02

SOURCE

SOURCE

KRS · krs.ms.gov.pl/krs · public REST API VIES · ec.europa.eu/taxation_customs/vies Companies House · api.companieshouse.gov.uk

Creditreform Bonität · creditreform.de D&B Financial Stress Score · dnb.com LSEG (Refinitiv) credit ratings

RED FLAG

RED FLAG

Entity not registered, dissolved, or different legal name on quote vs registry

Creditreform 4 (POOR) or worse · D&B FSS >70 (high stress) · payment default last 24mo

YELLOW FLAG

YELLOW FLAG

Active <12 months OR registered name + DBA differ (verify which entity owns the contract)

Creditreform 3.5 OR D&B FSS 50-70 · single late payment last 12mo

HOW

HOW

Pull entity record from registry. Match VAT/CRN/EIN to quote header. Check active status.

Pull credit report. Compare to category benchmark. Flag if score worse than 90% of peers.

TIME · 3 min · automated CADENCE · ANNUAL

TIME · 5 min · API CADENCE · ANNUAL · TRIGGER

Audited financials Y-1, Y-2, Y-3

Bank reference + payment terms verified

#03

#04

SOURCE

SOURCE

Bundesanzeiger · DE · bundesanzeiger.de KRS Annual Reports · PL Companies House filings · UK SEC EDGAR · US public

Bank reference letter (issued <90 days) SWIFT/IBAN verification via VIES Reference call to bank relationship mgr

RED FLAG

RED FLAG

No filed financials in 2+ countries · self-declared only · refused to share audited

Bank refused reference · IBAN doesn't validate · payment terms shifted >30 days mid-contract

YELLOW FLAG

YELLOW FLAG

Y-1 audited · Y-2 unaudited · or single-year auditor change without explanation

Net-30 terms requested when peer is Net-60 (cash flow stress) · partial bank ref only

HOW

HOW

Pull 3-year audited statements. Check revenue trend, EBITDA margin, working capital ratios.

Request bank reference letter. Verify IBAN/SWIFT against official banking registry.

TIME · 15 min CADENCE · ANNUAL

TIME · 10 min CADENCE · AT ONBOARDING

Sources: see Block 3 — Financial Health methodology references

Operational

07 · OPERATIONAL · CHECKS 5-8

Operational. Capacity matches contract.

ISO 9001 certificate current

Single-site dependency risk

#05

#06

SOURCE

SOURCE

ITC Standards Map · standardsmap.org Direct verify with issuing body (BSI, DNV, TÜV) IAF MLA-recognized certification body check

Supplier-disclosed facility list Satellite imagery (Sentinel free tier) Site-visit photos · 3rd-party audit reports

RED FLAG

RED FLAG

Cert expired · cert from non-IAF-recognized body · cert scope doesn't cover this product

100% capacity from 1 facility · facility in known earthquake zone · no business continuity plan

YELLOW FLAG

YELLOW FLAG

Cert expires in <6 months without renewal evidence · scope limitation language unclear

80%+ from 1 facility · plan not tested · BCP last reviewed >24mo

HOW

HOW

Verify cert# with issuing body. Check IAF MLA status. Match cert scope to product code.

Map all production sites. Calculate concentration risk. Verify with on-site visit if Tier-1.

TIME · 8 min CADENCE · ANNUAL · ON RENEWAL

TIME · 30 min CADENCE · ANNUAL

PPM defect rate & quality trending

Customer concentration risk

#07

#08

SOURCE

SOURCE

Customer-supplied PPM data Y-1, Y-2, Y-3 Incoming inspection rejection reports 3rd-party CAPA investigation reports

Supplier-disclosed top 10 customers Dun & Bradstreet customer-mix Public filings (10-K, annual report)

RED FLAG

RED FLAG

PPM >500 commodity OR >100 safety-critical · trending up Y-over-Y · CAPA not implemented

Single customer >60% of revenue · top-3 customers >85% · key customer in distress (cred. risk)

YELLOW FLAG

YELLOW FLAG

PPM 200-500 · stable but no improvement program · single material spike unexplained

Single customer 40-60% · sector concentration (e.g. all auto OEMs) · churn risk in top-5

HOW

HOW

Pull PPM data 3 years. Calculate trend. Compare to category benchmark.

Request top-10 customer disclosure under NDA. Calculate Herfindahl. Map to category.

TIME · 12 min · per-product CADENCE · QUARTERLY

TIME · 10 min CADENCE · ANNUAL

Sources: ITC Standards Map · IAF MLA · supplier-disclosed PPM data 2024-25

Geopolitical

08 · GEOPOLITICAL · CHECKS 9-12

Geopolitical. Five frameworks per supplier.

Sanctions & watchlist screening

Tariff exposure (HS-code level)

#09

#10

SOURCE

SOURCE

OFAC SDN List · sanctionssearch.ofac.treas.gov EU Consolidated Sanctions · webgate.ec.europa.eu/fsd
LSEG World-Check · refinitiv.com

EU TARIC · ec.europa.eu/taxation_customs US HTS · hts.usitc.gov USTR Section 301 list · current

RED FLAG

RED FLAG

ANY exact-match hit on entity, owner ≥25%, or top-3 management = walk away

Total tariff burden >18% FOB · category on Section 301 list AND tariff escalation pending

YELLOW FLAG

YELLOW FLAG

Fuzzy-match score >85% · sanctioned entity in same address building · former officer match

12-18% FOB · single-country exposure on rising-tariff category · CBAM-covered HS

HOW

HOW

Run name + address + DOB through OFAC + EU + UK + UN. Triple-check fuzzy matches.

Pull HS code from invoice. Calculate landed tariff burden. Compare to peer suppliers.

TIME · 5 min · automated CADENCE · QUARTERLY · ON LIST UPDATE

TIME · 8 min · per-shipment-type CADENCE · PER SHIPMENT

Export control · dual-use classification

CBAM exposure (verified emissions)

#11

#12

SOURCE

SOURCE

EU Dual-Use List · Annex I Reg 821/2021 US BIS Commerce Control List (CCL) ECCN Wassenaar Arrangement controlled items

EU CBAM Transitional Registry · dipl.cbam.europa.eu Supplier emissions verification (3rd-party) ETS-equivalent jurisdictions list

RED FLAG

RED FLAG

Dual-use classification without license · ITAR/CCL controls without auth · re-export control miss

Iron/steel/aluminium/cement origin Asia + no verified emissions data = €30-150/tonne added cost

YELLOW FLAG

YELLOW FLAG

Borderline classification (e.g. ECCN 3A001) without internal review · single country control

Self-reported emissions only · auditor not on EU-recognized list · data older than Y-2

HOW

HOW

Match HS code to dual-use schedule. Verify export license status. Check re-export controls.

Pull supplier emissions data. Verify auditor. Calculate CBAM exposure. Add to landed cost.

TIME · 12 min CADENCE · AT ONBOARDING · TRIGGER

TIME · 15 min · per-supplier CADENCE · QUARTERLY

Sources: OFAC · EU sanctions · USTR · EU CBAM Reg 2023/956 · BIS CCL

Esg

09 · ESG · CHECKS 13-16

ESG. Not values, compliance.

EcoVadis or Sedex SMETA score

Scope 1+2 emissions disclosure

#13

#14

SOURCE

SOURCE

EcoVadis · ecovadis.com (paid · supplier-paid disclosure) Sedex Members Ethical Trade Audit · sedex.com NQA · external 3rd-party audit

Supplier-supplied (verified by 3rd-party · GHG Protocol) CDP supply chain disclosure ISO 14064-3 verification reports

RED FLAG

RED FLAG

No EcoVadis · no SMETA · supplier refuses to share OR score 25 or below

No emissions disclosure · self-declared without 3rd-party verify · refuses CSRD-aligned format

YELLOW FLAG

YELLOW FLAG

EcoVadis Bronze (45-54) · expired audit >24mo · no improvement plan

Estimated only (no measurement) · auditor not GHG-Protocol recognized · data >Y-2

HOW

HOW

Request EcoVadis card or SMETA report. Verify with platform (not just supplier-supplied PDF).

Request Scope 1+2 with verifier letter. Match to category benchmark via SBTi tools.

TIME · 5 min · platform check CADENCE · ANNUAL

TIME · 10 min CADENCE · ANNUAL · CSRD-ALIGNED

ISO 14001 environmental cert

Modern slavery + forced labour declaration

#15

#16

SOURCE

SOURCE

ITC Standards Map · standardsmap.org Issuing body verify (BSI, DNV, TÜV NORD) Supplier-supplied cert + scope letter

EU Forced Labour Reg 2024/1781 attestation UK Modern Slavery Act statement (2015 Act) UFLPA Section 307 attestation

RED FLAG

RED FLAG

No ISO 14001 · cert from non-IAF body · scope excludes the production process for your product

No FLR-aligned attestation by Jun 2025 · UFLPA-listed entity · Xinjiang origin not disclosed

YELLOW FLAG

YELLOW FLAG

Cert expires <6mo without renewal · scope language unclear · single-site cert, multi-site supplier

Statement on file but not 2024-aligned · subcontractor visibility incomplete · Tier-2 not declared

HOW

HOW

Verify cert# via issuing body API. Confirm scope covers product. Check renewal.

Request signed FLR + UFLPA attestation. Map Tier-2 visibility (esp. cotton, polysilicon, tomatoes).

TIME · 8 min CADENCE · ANNUAL

TIME · 12 min CADENCE · ANNUAL · ENFORCEMENT JUN 2025

Sources: EU 2024/1781 · 19 USC § 1307(b) · GHG Protocol · EcoVadis methodology

Cyber

10 · CYBER · CHECKS 17-20

Cyber. Supplier breach = your breach.

ISO 27001 information security

Email breach exposure (HIBP)

#17

#18

SOURCE

SOURCE

ITC Standards Map verify Issuing body API check (BSI, DNV) SOC 2 Type II — alternative for US suppliers

Have I Been Pwned · haveibeenpwned.com (free API) SpyCloud breach intelligence DarkOwl deep-web monitoring

RED FLAG

RED FLAG

No ISO 27001 OR SOC 2 · cert expired >12mo · scope excludes systems handling your data

Domain in any 2024-25 breach · admin email pwned · password reuse detected on critical accounts

YELLOW FLAG

YELLOW FLAG

Cert expires <6mo · scope on info-only system not production · cert from non-IAF body

Domain in 2022-23 breach (resolved) · single user pwned not admin

HOW

HOW

Verify cert. Match scope to data flows. Request statement of applicability (SoA) for high-risk.

Run domain through HIBP API. Check breach details. Verify remediation status.

TIME · 10 min CADENCE · ANNUAL

TIME · 3 min · automated CADENCE · QUARTERLY

Active breach / incident in last 24mo

Data residency + processing agreement

#19

#20

SOURCE

SOURCE

FT/Reuters/Bloomberg breach reporting NCSC supplier alerts (UK) CISA known exploited vulnerabilities

Supplier-disclosed data centers (city-level) GDPR Art. 28 DPA in place Standard Contractual Clauses (SCC) for non-EU

RED FLAG

RED FLAG

Breach last 24mo · no public disclosure · supplier refuses to confirm/deny

Data flows to non-adequate country without SCC · no DPA · no breach notification SLA

YELLOW FLAG

YELLOW FLAG

Breach 24-48mo ago · resolved · no contractual breach-notification clause now in place

Single SCC missing (e.g. recent Schrems II requirement) · DPA outdated (pre-2023)

HOW

HOW

News scan supplier name + 'breach' + 'incident'. Request breach disclosure letter.

Request data flow map. Verify DPA terms. Check residency claims with on-site visit if Tier-1.

TIME · 8 min CADENCE · QUARTERLY · ON ALERT

TIME · 15 min CADENCE · ANNUAL · CONTRACT RENEWAL

Sources: ISO 27001:2022 · HIBP · GDPR Art. 28 · Schrems II SCC · CISA KEV

Redflag Matrix

11 · CONSOLIDATED RED-FLAG MATRIX

All 20 thresholds. One reference card.

Yellow = investigate · Red = walk away unless overridden by exec sponsor with documented business case.

CHECK

YELLOW

RED

FINANCIAL · #1-4

#1

Legal entity exists

registered <12mo

not registered / dissolved

#2

Credit score

Cred. 3.5 / FSS 50-70

Cred. 4 / FSS >70

#3

Audited financials

Y-1 only

none filed

#4

Bank reference

partial only

refused

OPERATIONAL · #5-8

#5

ISO 9001

expires <6mo

expired / non-IAF

#6

Single-site

80%+ from 1 site

100% / earthquake zone

#7

PPM defect

200-500 / no plan

> *500 commodity / >100 safety*

#8

Customer concentration

40-60% one customer

> *60% one / >85% top-3*

GEOPOLITICAL · #9-12

#9

Sanctions screening

fuzzy match >85%

exact match / sanctioned

#10

Tariff exposure

12-18% FOB

>18% FOB

#11

Export control

borderline classification

unclassified dual-use

#12

CBAM exposure

self-reported only

no data · Asia steel

ESG · #13-16

#13

EcoVadis / SMETA

Bronze / >24mo

none / score ≤25

#14

Scope 1+2

estimated only

none disclosed

#15

ISO 14001

expires <6mo

none / non-IAF

#16

Modern slavery

subcontractor gap

UFLPA-listed / no attestation

CYBER · #17-20

#17

ISO 27001 / SOC 2

expires <6mo

none / scope excludes

#18

Email breach

2022-23 resolved

2024-25 active

#19

Active incident

resolved 24-48mo

unresolved last 24mo

#20

Data residency

DPA outdated

non-adequate · no SCC

Sources: composite from Block 2 — all 20 verification points · Procurea audit framework

Cost Cases

12 · COST OF FAILURE · 4 NAMED CASES

$15B VW. $50M+ Inditex. $30M FCPA. $5M SolarWinds.

Four publicly-known supplier qualification failures. Each had a missed check that could have prevented the loss. The cost of one failure exceeds 100 years of audit budget.

APR 2013

SEP 2015

Rana Plaza · Inditex / Zara

Volkswagen emissions · Tier-1 firmware

Apparel · facility safety

Automotive · supplier control units

COST

COST

$15M settlement · $50M+ customer penalty · 8-week supply disruption

$15B recalls · $2.8B US fines · €900M EU · $4.3B class-action

CHECKS MISSED

CHECKS MISSED

#5 ISO 9001 facility scope · Sedex/SMETA structural audit

#17 ISO 27001 supplier scope · #19 firmware integrity audit · ABAC

LESSON

LESSON

Single-facility + earthquake zone + zero structural assessment = systemic failure

Tech supplier (firmware) needs deeper cyber audit than commodity hardware

SRC: Inditex 2013-14 corporate filings · CNN/BBC reporting SRC: VW Group 10-K filings 2015-20 · DOJ FCPA reports

2018-2020

DEC 2020

FCPA via mining supplier

SolarWinds Orion · 18,000+ orgs

Mining equipment · Sub-Saharan Africa

Software supplier · supply-chain attack

COST

COST

$800k legal + fines · $30M lost contracts (3-yr blacklist)

$500k-2M IR per org · $1M-5M remediation per org

CHECKS MISSED

CHECKS MISSED

#16 ABAC supplier audit · beneficial ownership check (CEO's brother = mining minister)

#17 SOC 2 Type II · build-environment access controls · #20 breach SLA

LESSON

LESSON

ABAC + beneficial ownership is not optional — prevents this exact pattern

Software ≠ secure by default — demand SOC 2 Type II for all SaaS

SRC: FT investigation 2020 · DOJ FCPA enforcement actions SRC: CISA AA20-352A · CNN/Reuters tech reporting · NIST SP 800-218

Sources: 10-Ks · DOJ enforcement · CISA · CNN/FT/Reuters reporting

Industry Addendum

13 · INDUSTRY-SPECIFIC ADDENDUM

Six industries. Additional checks beyond the 20.

Run all 20 baseline checks. Then add industry-specific checks below depending on supplier category. Pharma, electronics, and food typically need 8-12 additional checks.

INDUSTRY

KEY ADDITIONAL CHECKS

PRIMARY SOURCE

FDA inspection list (Form 483)

accessdata.fda.gov · 483 letters

PHARMACEUTICALS

GMP certification (current)

WHO PQS · supplier-direct

EMA ASMF / supplier docs

ema.europa.eu/asmf

Tier-2 contract mfr disclosure

supplier-disclosed (40% hide T-2)

RoHS 2.0 declaration

supplier · ECHA test reports

ELECTRONICS

REACH SVHC list (Q-updated)

echa.europa.eu/candidate-list

Conflict minerals (3TG)

RMI Conflict Minerals Reporting

IPC standards (-A-610, -A-620)

IPC.org · supplier audit

HACCP plan + audit

FDA / EFSA · 3rd-party audit

FOOD & BEVERAGE

BRC Global Standard cert

brcgs.com · ITC verify

FSSC 22000 certification

fssc.com · IAF MLA

Allergen control + traceability

supplier-direct + audit

Higg Index BRM (annual)

apparelcoalition.org

TEXTILES

BCI cotton license / OEKO-TEX

bettercotton.org · OEKO-TEX

ZDHC Roadmap to Zero

roadmaptozero.com · Gateway

Modern slavery (CSDDD-aligned)

UK MSA · EU CSDDD

IATF 16949 certification

iatf.org · supplier-direct

AUTOMOTIVE

VDA 6.3 process audit

VDA · 3rd-party audit

Customer-specific approvals (PPAP)

CSA per OEM

IATF supplier self-assessment

SAQ in IATF database

AS9100D certification

ITC · OASIS database

AEROSPACE

Customer + Nadcap process audit

Nadcap.com · OEM audit

ITAR/EAR export classification

DDTC · BIS CCL

Counterfeit parts prevention (CCAP)

SAE AS5553 / NIST

Sources: FDA · ECHA · IATF · Higg Index · ZDHC · WHO PQS · industry standard bodies

Cadence Calendar

14 · RE-CHECK CADENCE CALENDAR

Quarterly cadence. Trigger-event overrides.

Standard rhythm: re-check 4-7 dimensions every quarter, all 20 annually. Trigger events (sanctions list update, breach disclosure) override the calendar.

QUARTERLY RE-CHECK CALENDAR · MIN VIABLE

Q1

Q2

Q3

Q4

FINANCIAL

#1 · #2

#3, #4 annual

OPERATIONAL

#7

#5, #6, #8 annual

GEOPOLITICAL

#9 · #10 · #12

sanctions: trigger-based

ESG

#13 · #14

H1 + H2 due dates

CYBER

#18 · #19

breach: trigger-based

TRIGGER EVENTS — OVERRIDE CALENDAR

OFAC/EU sanctions list update · CBP UFLPA entity addition · CISA KEV catalog update · supplier breach disclosure · FDA Form 483 issuance · public bankruptcy filing · audit firm change · facility relocation · senior management change

Sources: composite from Block 2 cadence guidance · Procurea audit framework

Workflow Gantt

15 · 45-MINUTE AUDIT WORKFLOW

Standard new-supplier audit. 45 minutes. Five phases.

Procurement analyst runs minutes 0-30. Risk + IT specialists pick up minutes 30-45 if escalated. Most suppliers complete clear within 45 min if data sources pre-bookmarked.

WORKFLOW · 45 MIN · 5 ROLES

0m

5m

10m

15m

20m

25m

30m

35m

40m

45m

PROCUREMENT

Phase 1 · Financial #1-4

Phase 2 · Operational #5-8

Phase 3 · Geo #9-12

Analyst

RISK MGR

Geo escalation

Phase 4 · ESG #13-16

Risk specialist

IT SECURITY

Phase 5 · Cyber #17-20

InfoSec specialist

LEGAL

Sanctions verify

DPA + SCC review

Compliance

DECISION

GO/NO-GO

Procurement lead

ESCALATION GATE · 18m

45m — STANDARD AUDIT

5m — QUICK-SCAN

1d — DEEP AUDIT

45/yr — PER ANALYST

all 20 checks · pre-bookmarked sources

checks #1, #9 · single PO < €25k

Tier-1 strategic + safety-critical

~1 supplier audit per business day

Methodology: EcoVadis 45-min protocol · ISO 31000 risk-tier audit framework

Printable Onepager

16 · PRINTABLE ONE-PAGER

Twenty checks. One A4. Pin to your wall.

Run on every new supplier · 45 min · re-check quarterly

FINANCIAL · CHECKS 1–4

FINANCIAL HEALTH

1. Legal entity exists · KRS · VIES
2. Credit score · Creditreform / D&B
3. Audited financials Y-1 to Y-3
4. Bank reference + payment terms

OPERATIONAL · CHECKS 5–8

OPERATIONAL RESILIENCE

5. ISO 9001 cert current · IAF MLA
6. Single-site dependency check
7. PPM defect trending Y-3
8. Customer concentration ≤60%

GEOPOLITICAL · CHECKS 9–12

GEOPOLITICAL & REGULATORY

9. Sanctions screening · OFAC + EU
10. Tariff exposure HS-code (≤18%)
11. Export control · ECCN · dual-use
12. CBAM verified emissions

ESG · CHECKS 13–16

ESG & COMPLIANCE

13. EcoVadis or Sedex SMETA
14. Scope 1+2 emissions verified
15. ISO 14001 environmental cert
16. Modern slavery + FLR attestation

CYBER · CHECKS 17–20

CYBER & INFOSEC

17. ISO 27001 / SOC 2 Type II
18. HIBP breach exposure check

19. Active incident last 24mo
20. Data residency + DPA + SCC

PROCUREA.IO · v3.0 · APRIL 2026 · NEXT REVISION OCT 2026

Print A4 portrait · share with team · pin to audit-room wall

Back Cover Cta

END · NEXT STEPS

Find audit-ready vendors in 20 minutes.

Need to run this 20-point checklist on a clean panel? Procurea sources 50-250 verified vendors per category — registry data and certificates verified during the pipeline. Then you run the audit.

BUILT FOR EU MID-MARKET PROCUREMENT TEAMS · GDPR-NATIVE · €30M–€500M REVENUE

NOT FOR: ENTERPRISES WITH ACTIVE SAP ARIBA / COUPA CONTRACTS — STAY THERE

PLAYBOOK READER OFFER

10 campaigns. Free. — Worth $119 — yours free as a playbook reader.

Start your first campaign →

procurea.io / signup

20 MIN PIPELINE

NO CREDIT CARD

50–250 VENDORS / CAMPAIGN

Talk to a procurement engineer

Book →

30 min · we walk through your panel · live audit demo

METHODOLOGY · 40+ PRIMARY SOURCES

EU 2022/2464 (CSRD) · 2023/956 (CBAM) · 2024/1760 (CSDDD) · 2024/1781 (FLR) · 19 USC § 1307(b) (UFLPA) · OFAC SDN · LSEG World-Check · KRS · Bundesanzeiger · Companies House · VIES · Have I Been Pwned · ISO Survey 2024 · IAF MLA · ITC Standards Map · CBP UFLPA Stats 2025 · CISA AA20-352A · GHG Protocol · EcoVadis · Sedex SMETA · GDPR Art. 28 · Schrems II SCC · CBP audit data 2024